

Bullrun (stylized BULLRUN) is a clandestine, highly classified program to crack encryption of online communications and data, which is run by the United States National Security Agency (NSA). The British Government Communications Headquarters (GCHQ) has a similar program codenamed Edgehill. According to the Bullrun classification guide published by The Guardian, the program uses multiple methods including computer network exploitation, interdiction, industry relationships, collaboration with other intelligence community entities, and advanced mathematical techniques.

Information about the program's existence was leaked in 2013 by Edward Snowden. Although Snowden's documents do not contain technical information on exact cryptanalytic capabilities because Snowden did not have clearance access to such information, they do contain a 2010 GCHQ presentation which claims that "vast amounts of encrypted Internet data which have up till now been discarded are now exploitable". A number of technical details regarding the program found in Snowden's documents were additionally censored by the press at the behest of US intelligence officials. Out of all the programs that have been leaked by Snowden, the Bullrun Decryption Program is by far the most expensive. Snowden claims that since 2011, expenses devoted to Bullrun amount to \$800 million. The leaked documents reveal that Bullrun seeks to "defeat the encryption used in specific network communication technologies".

Naming and access

According to the NSA's Bullrun Classification Guide, Bullrun is not a Sensitive Compartmented Information (SCI) control system or compartment, but the codeword has to be shown in the classification line, after all other classification and dissemination markings. Furthermore, any details about specific cryptographic successes were recommended to be additionally restricted (besides being marked Top Secret//SI) with Exceptionally Controlled Information labels; a non-exclusive list of possible Bullrun ECI labels was given as: APERIODIC, AMBULANT,

AUNTIE, PAINTEDEAGLE, PAWLEYS, PITCHFORD, PENDLETON, PICARESQUE, and PIEDMONT without any details as to what these labels mean.

Access to the program is limited to a group of top personnel at the Five Eyes (FVEY), the NSA and the signals intelligence agencies of the United Kingdom (GCHQ), Canada (CSE), Australia (ASD), and New Zealand (GCSB). Signals that cannot be decrypted with current technology may be retained indefinitely while the agencies continue to attempt to decrypt them, approach known as "harvest now, decrypt later".

Methods

Through the NSA-designed Clipper chip, which used the Skipjack cipher with an intentional backdoor, and using various specifically designed laws such as CALEA, CESA and restrictions on export of encryption software as evidenced by *Bernstein v. United States*, the U.S. government had publicly attempted in the 1990s to ensure its access to communications and ability to decrypt. In particular, technical measures such as key escrow, a euphemism for a backdoor, have met with criticism and little success.

The NSA encourages the manufacturers of security technology to disclose backdoors to their products or encryption keys so that they may access the encrypted data. However, fearing widespread adoption of encryption, the NSA set out to stealthily influence and weaken encryption standards and obtain master keys—either by agreement, by force of law, or by computer network exploitation (hacking).

According to a Bullrun briefing document, the agency had successfully infiltrated both the Secure Sockets Layer as well as some virtual private networks (VPNs). The New York Times reported that: "But by 2006, an N.S.A. document notes, the agency had broken into communications for three foreign airlines, one travel reservation system, one foreign government's nuclear department and another's Internet service by cracking the virtual private networks that protected them. By 2010, the Edgehill program, the British

counterencryption effort, was unscrambling VPN traffic for 30 targets and had set a goal of an additional 300."

As part of Bullrun, NSA has also been actively working to "Insert vulnerabilities into commercial encryption systems, IT systems, networks, and endpoint communications devices used by targets". The New York Times has reported that the random number generator Dual_EC_DRBG contains a back door, which would allow the NSA to break encryption keys generated by the random number generator. Even though this random number generator was known to be insecure and slow soon after the standard was published, and a potential NSA kleptographic backdoor was found in 2007 while alternative random number generators without these flaws were certified and widely available, RSA Security continued using Dual_EC_DRBG in the company's BSAFE toolkit and Data Protection Manager until September 2013. While RSA Security has denied knowingly inserting a backdoor into BSAFE, it has not yet given an explanation for the continued usage of Dual_EC_DRBG after its flaws became apparent in 2006 and 2007. It was reported on December 20, 2013, that RSA had accepted a payment of \$10 million from the NSA to set the random number generator as the default. Leaked NSA documents state that their effort was "a challenge in finesse" and that "Eventually, N.S.A. became the sole editor" of the standard.

By 2010, the leaked documents state that the NSA had developed "groundbreaking capabilities" against encrypted Internet traffic. A GCHQ document warned however "These capabilities are among the SIGINT community's most fragile, and the inadvertent disclosure of the simple 'fact of' could alert the adversary and result in immediate loss of the capability." The document later states that "there will be NO 'need to know.'" Several experts, including Bruce Schneier and Christopher Soghoian, had speculated that a successful attack against RC4, an encryption algorithm used in at least 50 percent of all SSL/TLS traffic at the time, was a plausible avenue, given several publicly known weaknesses of RC4. Others have speculated that NSA has gained ability to crack 1024-bit RSA/DH keys. RC4 has since been prohibited for

all versions of TLS by RFC 7465 in 2015, due to the RC4 attacks weakening or breaking RC4 used in SSL/TLS.

Fallout

In the wake of Bullrun revelations, some open source projects, including FreeBSD and OpenSSL, have seen an increase in their reluctance to (fully) trust hardware-based cryptographic primitives.

Many other software projects, companies and organizations responded with an increase in the evaluation of their security and encryption processes. For example, Google doubled the size of their TLS certificates from 1024 bits to 2048 bits.

Revelations of the NSA backdoors and purposeful complication of standards has led to a backlash in their participation in standards bodies. Prior to the revelations the NSA's presence on these committees was seen as a benefit given their expertise with encryption.

There has been speculation that the NSA was aware of the Heartbleed bug, which caused major websites to be vulnerable to password theft, but did not reveal this information in order to exploit it themselves.

Etymology

The name "Bullrun" was taken from the First Battle of Bull Run, the first major battle of the American Civil War. Its predecessor "Manassas", is both an alternate name for the battle and where the battle took place. "EDGEHILL" is from the Battle of Edgehill, the first battle of the English Civil War.

See also

HTTPS

IPsec

Mass surveillance

Mass surveillance in the United Kingdom

Mass surveillance in the United States

MUSCULAR

PRISM

Tailored Access Operations

Transport Layer Security

Voice over IP

References

External links

Crucial Unanswered Questions about the NSA's BULLRUN Program

Documents Reveal N.S.A. Campaign Against Encryption

Defending Against Crypto Backdoors - Schneier on Security

Cryptography Opening Discussion: Speculation on "BULLRUN" John Gilmore

https://www.cs.auckland.ac.nz/~pgut001/pubs/crypto_wont_help.pdf